Xiamen University

Tight Generic PRF Security of HMAC and NMAC

Yaobin Shen

Joint work with Xiangyang Zhang, Lei Wang, Dawu Gu

March 20@ASK 2026, Singapore

1 Background

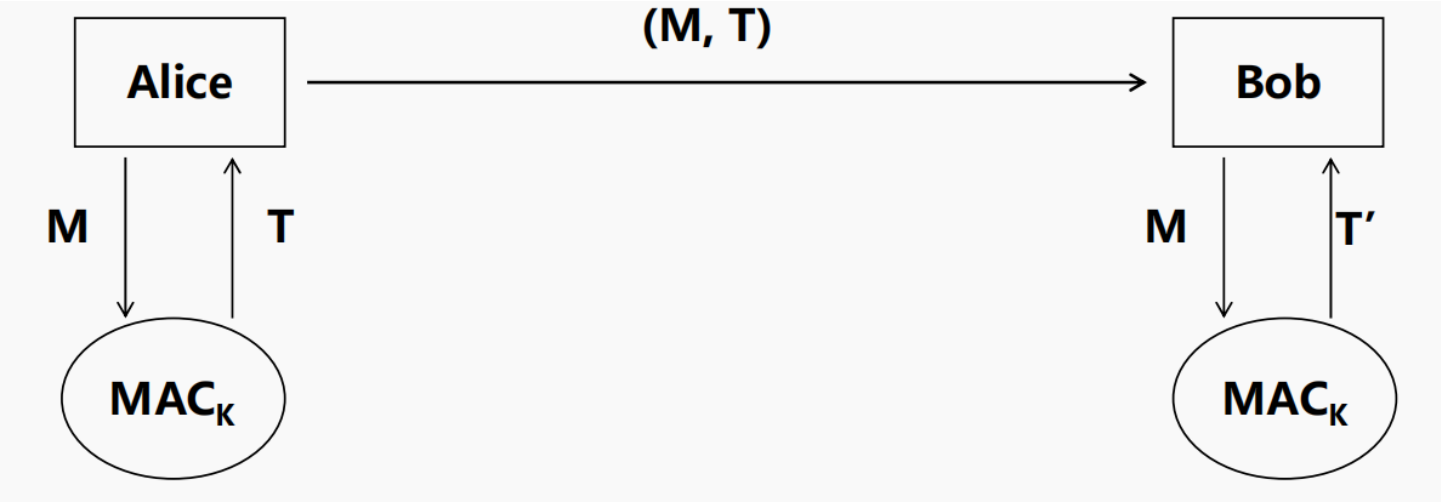
2 Our Results

3 Proof Sketch

4 Attacks

Message Authentication Code (MAC)

- Symmetric-key algorithms for integrity and authenticity



- Three ways to build a MAC
  - using a hash function (**HMAC**, **NMAC**, NI-MAC)
  - using a blockcipher (CBC-MAC, OMAC, PMAC)
  - using a universal hash function (GMAC, Poly1305-AES, Badger)

HMAC&NMAC

- Compression function $h : \{0,1\}^c \times \{0,1\}^b \rightarrow \{0,1\}^c$
- Merkle-Damgård transform $\mathsf{Casc} : \{0,1\}^c \times \{0,1\}^* \rightarrow \{0,1\}^c$

$$m_1 \parallel m_2 \parallel \ldots \parallel m_\ell \leftarrow M \parallel \mathsf{pad}(|M|), \quad z_0 = IV, \; z_i = h(z_{i-1}, m_i), \quad \mathsf{Casc}(IV, M) = z_\ell$$

- $\mathsf{NMAC}((K_1, K_2), M) = \mathsf{Casc}(K_2, \mathsf{Casc}(K_1, M))$

  $\mathsf{HMAC}(K, M) = \mathsf{Casc}(IV, K_2 \parallel \mathsf{Casc}(IV, K_1 \parallel M))$

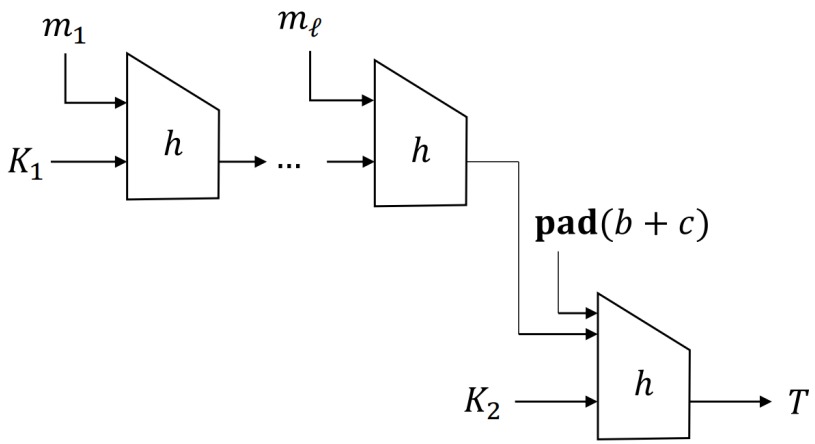


Fig. 2: A pictorial illustration of NMAC.

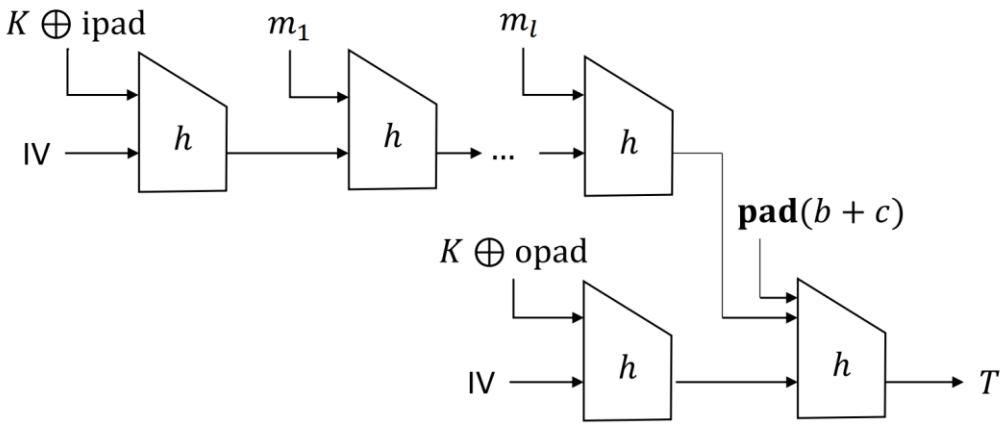


Fig. 3: A pictorial illustration of HMAC.

HMAC

$$\mathrm{HMAC}(K, M) = \mathrm{Casc}(IV, (K \oplus opad) \parallel \mathrm{Casc}(IV, (K \oplus ipad) \parallel M))$$

- A single key K derives the two prefixes $K \oplus opad$ and $K \oplus ipad$
- Allows the usage of existing implementation of a hash function in a black-box manner

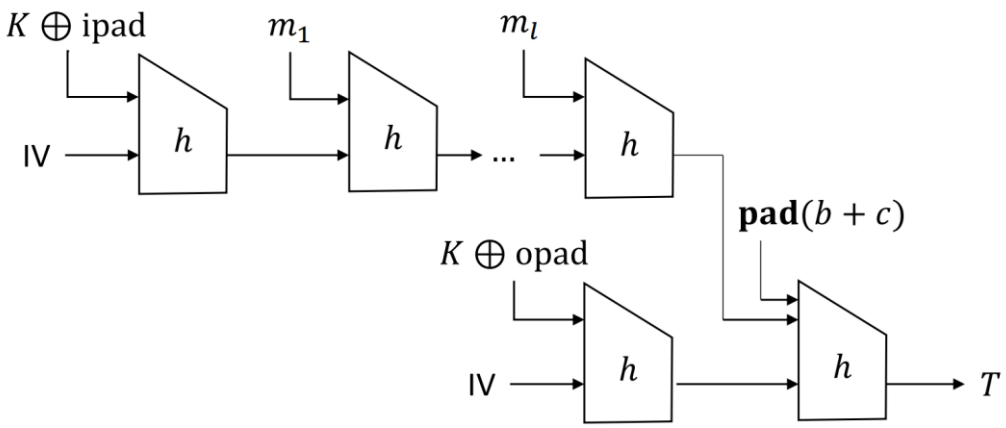


Fig. 3: A pictorial illustration of HMAC.

- One of the predominant ways to key a hash function and obtain a PRF or MAC
- Standardized by ANSI, IETF, ISO/IEC, and NIST
- Widely deployed in Internet security protocols (e.g., SSL/TLS, SSH, and IPsec) with billions of daily users

NMAC

$$\mathrm{NMAC}((K_1, K_2), M) = \mathrm{Casc}(K_2, \mathrm{Casc}(K_1, M))$$

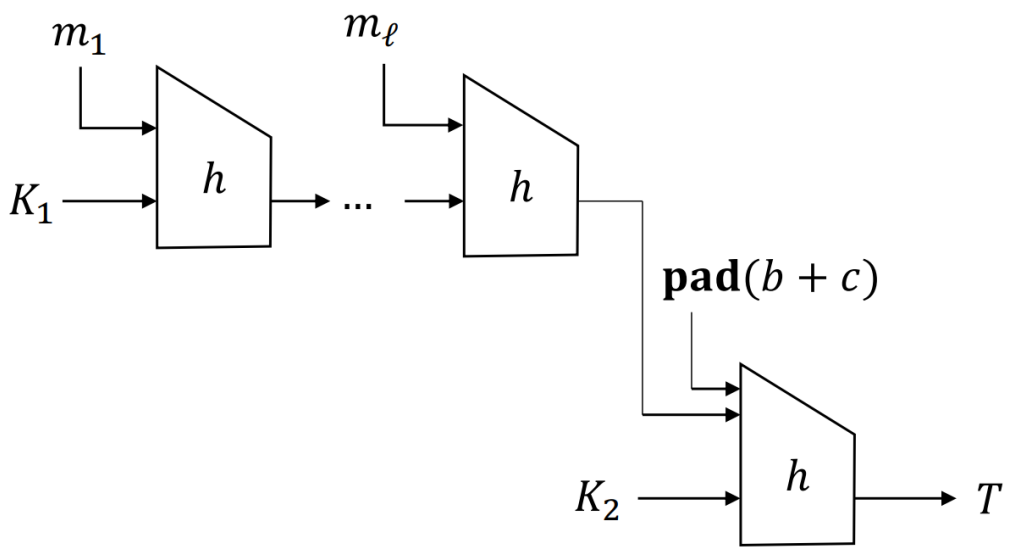


Fig. 2: A pictorial illustration of NMAC.

- Replace the public IV by a secret key K_1 and finalize with a second secret key K_2
- Conceptually clean
  - A keyed cascade inside another keyed cascade
- Less practical than HMAC
  - The hash function cannot be used in a black-box manner.

- NMAC is a cleaner theoretical cousin of HMAC, so understanding both matters for practice and theory.

Prior works on PRF security

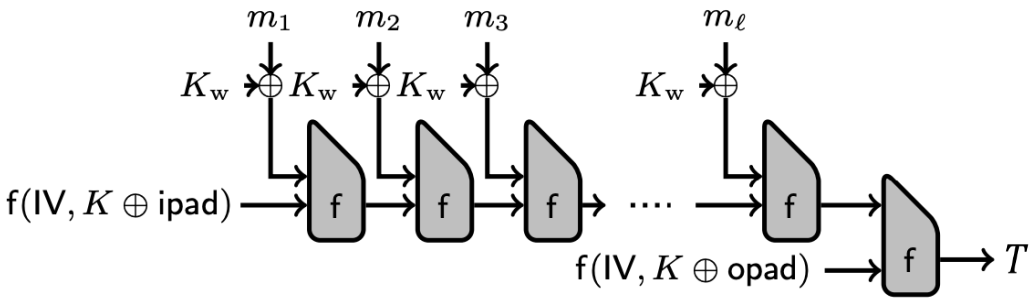
- HMAC and NMAC were proved secure as PRFs in the standard model [BCK96], with later extensions under weaker assumptions [Bel06] and a tight bound in the uniform setting [GPR14].
  - These proofs do not cleanly quantify the effect of offline compression-function queries that underlie generic attacks on hash-based MACs
  - The importance of analyzing the generic PRF security of HMAC in the ideal compression function model was highlighted in [GPR14].
- The generic PRF distinguishing attack against HMAC and NMAC requires only $2^{c/2}$ construction queries, but **no compression function queries**.

[BCK96] M. Bellare, R. Canetti, and H. Krawczyk. Keying hash functions for message authentication. CRYPTO 2024.
[Bel06] M. Bellare. New proofs for NMAC and HMAC: security without collision resistance. CRYPTO 2006.
[GPR14] P. Gazi, K. Pietrzak, and M. Rybár. The exact prf-security of NMAC and HMAC. CRYPTO 2014.
[BO95]B. Preneel and P. C. van Oorschot. Mdx-mac and building fast macs from hash functions. CRYPTO 1995.

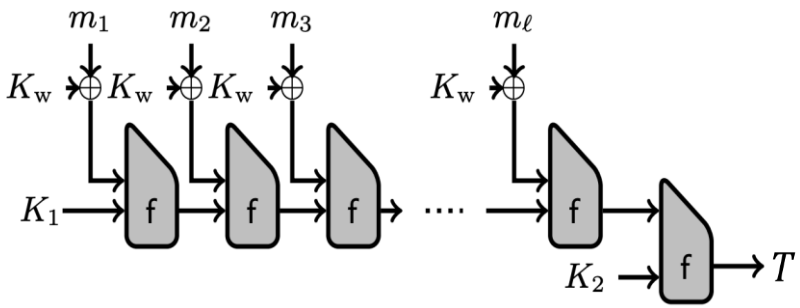
Our focus

"How to prove a tight bound in terms of compression function queries and construction queries on the generic PRF security of HMAC and NMAC?"

- The question was highlighted by Gazi et al. [GPT15] and Bellare et al. [BBT16].
  - Gazi et al. [GPT15] obtained tight bounds only for WHMAC and WNMAC, which use additional key material to whiten message blocks.



WHMAC



WNMAC

[GPT15]P. Gazi, K. Pietrzak, and S. Tessaro. Generic security of NMAC and HMAC with input whitening. ASIACRYPT 2015.
[BBT16] M. Bellare, D. J. Bernstein, and S. Tessaro. Hash-function based prfs: AMAC and its multi-user security. In Advances in Cryptology - EUROCRYPT 2016

1 Background

2 Our Results

3 Proof Sketch

4 Attacks

Our Contributions

- Prove the generic PRF security of HMAC and NMAC and establish tight security bounds through matching cryptanalytic attacks.
- Provide proofs in the multi-user setting and show that security does not degrade with the number of users.
- Close the gap in the generic PRF security analysis of HMAC/NMAC.

Our Contributions (HMAC)

Theorem 1. *Let $\mathcal{A}$ be an adversary against the multi-user PRF security of* HMAC *as defined in the game of Fig. 7. Assume that $\mathcal{A}$ makes at most p compression function queries, at most q construction queries of maximal block length ℓ. We have*

dominant terms

$$\mathsf{Adv}^{\mathrm{prf}}_{\mathsf{HMAC}}(\mathcal{A}) \leq \boxed{\frac{pq\ell}{2^c} + \frac{5q^2\ell}{2^c}} + \frac{6q^2}{2^c} + \frac{pq}{2^c} + \frac{32q^2\ell^4}{2^{2c}} + \frac{q^2(b+6+\ln p)}{2^{b+1}} + \frac{4pq}{2^b} + \frac{q^2\ell(\ln p+2)}{2^b} .$$

- Imply that the number of compression function queries and the maximal block length of a message also have certain impact on the PRF security of HMAC.
- Carried out in the multi-user setting for HMAC's wide deployment in security protocols with billions of daily active users.

Our Contributions (HMAC)

Xiamen University

- The bound is tight
  - Attack 1 matches $\frac{pq\ell}{2^c}$ using properties of the functional graph of a random function.
  - Attack 2 matches $\frac{q^2\ell}{2^c}$ by adapting the NI-construction attack to HMAC.

- Concrete interpretation
  - With $q \approx 2^{\frac{c}{2}}/\sqrt{\ell}$, $p \approx 2^{\frac{c}{2}}/\sqrt{\ell}$, assuming $\ell \leq 2^{64}$, the claimed security threshold ranges from 2^{92} for SHA-224 to 2^{224} for SHA-512 for both q and p
  - The term $\frac{pq\ell}{2^c}$ gives an explicit description of how the number of compression function queries p scales with the number of construction queries $q < 2^{\frac{c}{2}}/\sqrt{\ell}$

Our Contributions (NMAC)

- NMAC gets almost the same dominant bound.

Theorem 2. *Let $\mathcal{A}$ be an adversary against the multi-user PRF security of* NMAC *as defined in the game of Fig. 7. Assume that $\mathcal{A}$ makes at most p compression function queries, at most q construction queries of maximal block length ℓ. We have*

dominant terms

$$\mathsf{Adv}^{\mathrm{prf}}_{\mathsf{NMAC}}(\mathcal{A}) \leq \boxed{\frac{pq\ell}{2^c} + \frac{4q^2\ell}{2^c}} + \frac{4q^2}{2^c} + \frac{2pq}{2^c} + \frac{32q^2\ell^4}{2^{2c}} + \frac{q^2(b+c+3+\ln p)}{2^{b+1}} + \frac{q^2\ell(\ln p+1)}{2^b} .$$

- Subtle differences between these two analyses as NMAC and HMAC are equipped with different keying mechanisms, especially if we want to obtain a tight bound

1 Background

2 Our Results

3 Proof Sketch

4 Attacks

Proof framework at a glance

Xiamen University

procedure INITIALIZE
$K_1, K_2, \cdots, \leftarrow\$ \mathcal{K}$
$f_1, f_2, \cdots, \leftarrow\$ \mathrm{Func}(\mathcal{D}, \mathcal{R})$
$b \leftarrow\$ \{0, 1\}$

procedure PRIM(u, v)
return $h(u, v)$

procedure EVAL(i, M)
$T_1 \leftarrow F(K_i, M)$
$T_0 \leftarrow f_i(M)$
return T_b

procedure FINALIZE(b')
return $(b' = b)$

Fig. 1: Game $\mathbf{G}_F^{\mathrm{prf}}$ defining multi-user PRF security of the construction F.

1 Augmented transcripts

Reveal keys and internal calls after the interaction. In the ideal world, reveal dummy internal calls instead.

2 Define bad events

Define collisions and structural events that would make a transcript distinguishable or hard to analyze

3 Union bound for bad events

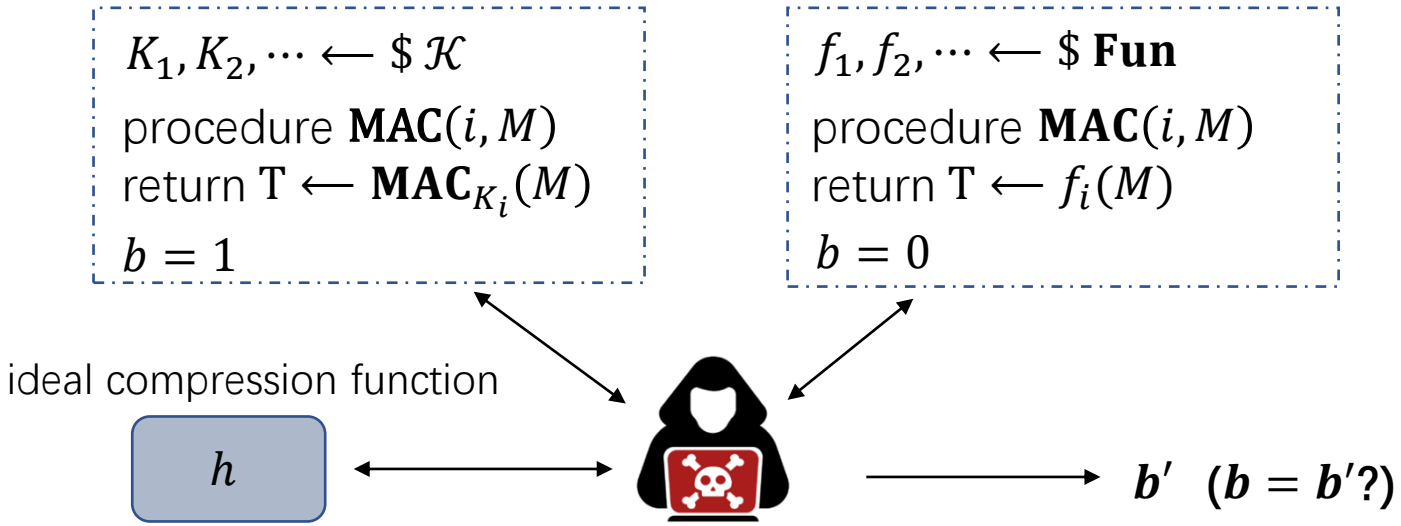
Bound the probability of bad transcripts in the ideal world.

4 Ratio on good transcripts

Show that on every good transcript, the real and ideal worlds assign exactly the same probability. Conclude the theorem by H-coefficient technique.

Key difficulty: account for offline compression-function queries tightly, without paying the folklore $q^2\ell^2 / 2^c$ penalty.

Model Setting



$$\mathbf{Adv}_{\mathbf{MAC}}^{\mathbf{muprf}}(\mathcal{A}) = 2(\Pr[b = b'] - \frac{1}{2})$$

- After querying, reveal the keys of each user and entries of internal compression function calls.
- In the ideal world, give the adversary truly random keys and dummy internal compression function calls for each construction query.

Bad Events

Xiamen University

bad_1 Cross-user key collision

Two different users accidentally receive the same key.

bad_2 Key meets offline query

A user key prefix collides with some offline compression-function input.

bad_3 Last-call collision across users

Two different users end up with the same final compression input.

bad_4 Last-call collision within one user

Two construction queries to the same user collide at the last call.

bad_5 Last-call hits offline query

The final internal h-call of a construction query was already seen through an offline primitive query.

bad_6 Last-call hits internal call

The final internal h-call of a construction query collides with another internal call.

$\mathbf{bad_4}$ Decomposition

Xiamen University

EA **a collision with constrain**

Some internal pair (x_α, y_α) is fresh, but the next pair $(x_{\alpha+1}, y_{\alpha+1})$ already lies in Q_h.

$$\frac{pq\ell}{2^c}$$

EB **partially fresh chains**

If two construction queries collide while at least one last chain segment stays fresh

$$O\left(\frac{q^2\ell}{2^c}\right)$$

EC **fully known chains**

If both chains are already fully determined by offline queries, count how many keys can satisfy the collision and cap that number by a smooth threshold γ.

$$\gamma \approx e2^{b-c} + 2(\ell+1)\ln p + b\ln 2$$

- The treatment of EC is rather delicate and necessitates the formulation of a smooth threshold γ to achieve tightness.

EC Calculation: Reduction Setup

- Let S be the set of all candidate messages reconstructed from Q_h.
- For two distinct messages $M, M' \in S$, define a key-dependent difference function $g_{M,M'}(K)$

$$g_{M,M'}(K) = \mathsf{Casc}(IV, K \parallel M) \oplus \mathsf{Casc}(IV, K \parallel M')$$

- Under event EC, a collision $z^a_{\ell_a} = z^b_{\ell_b}$ implies $M_a, M_b \in S$ and $g_{M_a,M_b}(K_i) = 0^c$.
- Introduce a threshold γ for the number of distinct keys that solve $g_{M,M'}(K_i) = 0^c$ for fixed M, M'.
  - Define **mkeys**: there exist γ distinct keys $\overline{K}_1, \cdots, \overline{K}_\gamma$ and two distinct messages M, M' with $g_{M,M'}(\overline{K}_i) = 0^c$ for all i.

Split EC into an easy part and a rare bad event.

$$\begin{aligned}\Pr\left[z^a_{\ell_a} = z^b_{\ell_b} \wedge \mathbf{EC}\right] &\le \Pr\left[z^a_{\ell_a} = z^b_{\ell_b} \wedge \mathbf{EC} \mid \neg\mathbf{mkeys}\right] + \Pr\left[\mathbf{mkeys}\right] \\ &\le \frac{\gamma - 1}{2^b} + \Pr\left[\mathbf{mkeys}\right] .\end{aligned}$$

EC Calculation: Bounding mkeys and Choosing γ

Xiamen University

Bounding **mkeys**

- Bounding one message pair: For a pair of M, M' and each candidate key, if $g_{M,M'}(\overline{K}_i) = 0^c$, then $\Pr[h(IV, \overline{K}_i \oplus ipad) = u_1] = 1/2^c$ where $(u_1, v_1) \in Q_h$ and $m_1 = v_1$. Consider the independence of γ distinct keys, then $\Pr[\forall i \in [\gamma]: g_{M,M'}(\overline{K}_i) = 0^c] = (1/2^c)^\gamma$.
- Counting all possibilities: $|S| \leq \Sigma_{i=1}^{\ell} p^i$, so the number of message pairs is at most $p^{2(\ell+1)}$; the number of γ-tuples of distinct keys is upper bounded by $C_{2^b}^{\gamma}$. Thus

$$\Pr[\mathbf{mkeys}] \leq p^{2(\ell+1)} \cdot \binom{2^b}{\gamma} \cdot \left(\frac{1}{2^c}\right)^\gamma \leq p^{2(\ell+1)} \cdot \left(\frac{e2^{b-c}}{\gamma}\right)^\gamma$$

Choosing γ

- $\gamma = \left\lceil e \cdot 2^{b-c} + 2(\ell+1)\ln p + b\ln 2 \right\rceil \leq 2^b$ so that $p^{2(\ell+1)} \cdot (e2^{b-c}/\gamma)^\gamma \leq 1/2^b$, and finally

$$\Pr\left[z_{\ell_a}^a = z_{\ell_b}^b \wedge \mathbf{EC}\right] \leq \frac{e}{2^c} + \frac{2(\ell+1)\ln p + b\ln 2 + 1}{2^b}$$

EC is controlled by a compression-term $e/2^c$ plus a small key-search term scaled by message length ℓ and offline-query count p.

1 Background

2 Our Results

3 Proof Sketch

4 Attacks

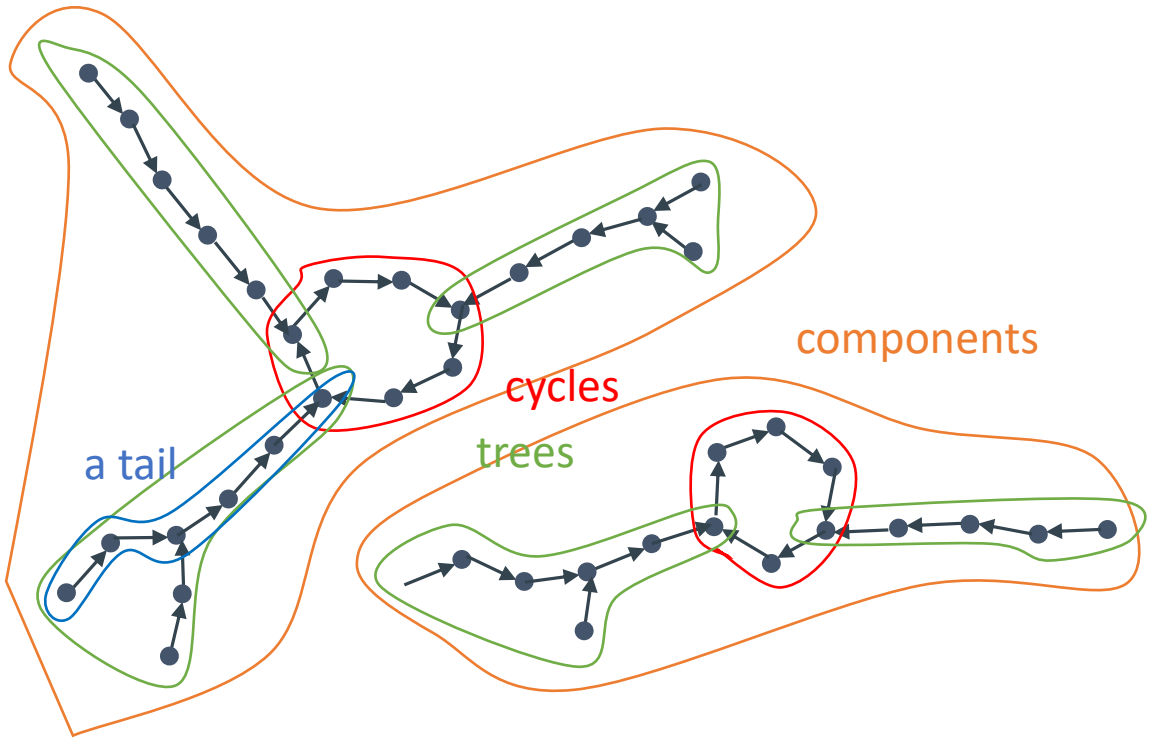
Attack I: functional graph of h_{0^n}

Functional graph

- Given a public n-bit function $h: \{0,1\}^n \to \{0,1\}^n$
- Node i goes to node j iff $h(i) = j$
- Component / Cycle / Tree / Tail

Expected properties of a random mapping over 2^n points[FO89, FS09]

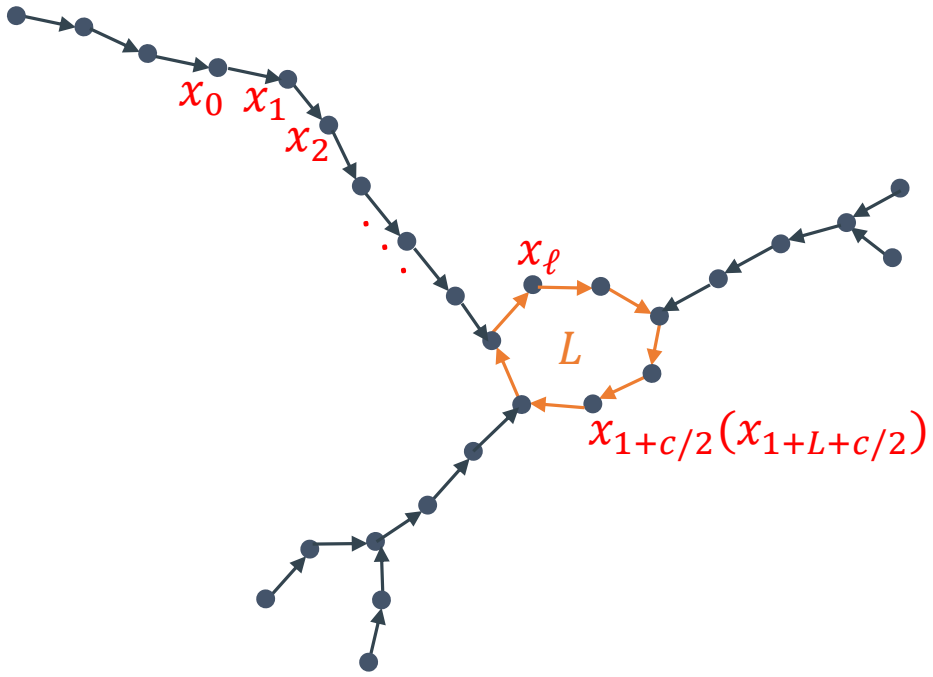
- Largest component size: $0.7582 \cdot 2^n$
- Tail length: $0.62 \cdot 2^{n/2}$
- Cycle length: $0.62 \cdot 2^{n/2}$
- Tree size: $0.34 \cdot 2^{n/2}$



[FO89] P. Flajolet and A. M. Odlyzko. Random mapping statistics. EUROCRYPT 1989.
[FS09] P. Flajolet and R. Sedgewick. Analytic Combinatorics. Cambridge University Press, 2009.

Attack I: functional graph of h_{0^n}

- Functional graph of h_{0^n} where $h_{0^n}(x) = h(x, 0^n)$ has a giant component with long tails and a cycle.



1. Offline: find a cycle of h_{0^n}

Repeat until it lies in the giant component; record its length L.

2. Online: pick a random first block m and query two tags

$$M_1 = m \parallel (0^n)^{2^{c/2}} \parallel 1^n \parallel (0^n)^{2^{c/2}+L}$$

$$M_2 = m \parallel (0^n)^{2^{c/2+L}} \parallel 1^n \parallel (0^n)^{2^{c/2}}$$

3. Decision: if Tag(M_1) = Tag(M_2), output 1; otherwise output 0.

The attack turns offline cycle information into an online tag collision.

Attack I: functional graph of h_{0^n}

- Probability Gap
  - Ideal PRF: the offline cycle search is independent of the online tags, so a collision appears only with probability 2^{-c}.
  - HMAC: the two long 0^n stretches likely drive both computations onto the same cycle; shifting by L keeps the cycle position aligned.
  - The 1^n jump stays in the giant component with probability about 0.7582, and each long 0^n run reaches the cycle with probability at least 1/2.

Real: Pr[collision] $\approx \left(\mathbf{0.7582} \cdot \frac{\mathbf{1}}{\mathbf{2}}\right)^{\mathbf{2}} \approx \mathbf{0.14}$;
Ideal: Pr[collision] $= 2^{-c}$
Advantage $\approx \mathbf{0.14}$

- Cost
  - About $O(2^{c/2})$ offline compression queries + only 2 MAC queries; the length of each queried message is about $3 \cdot 2^{c/2}$.

Attack II: repeated zero suffixes

- Get one collision anywhere before the common suffix
  - Choose q messages of the same length ℓ blocks $M_i = x_i \parallel 0^{b(\ell-1)}$ where $x_1, \cdots, x_q$ are distinct first blocks and all remaining $\ell - 1$ blocks are identical $(0^n, \cdots, 0^n)$.
  - For each pair (i, j) and position $\alpha \in \{0, \ldots, \ell - 1\}$, inspect the internal state after α blocks.

If the internal states are equal after α blocks, then both computations process exactly the same suffix from the same state, so HMAC(K, M_i) = HMAC(K, M_j).

- For any fixed triple (i, j, α), the internal collision probability is about 2^{-c} $(\ell \ll 2^{c/2})$ and the number of candidate triples is $\Theta(q^2\ell)$.
  - Ideal PRF: only the usual birthday term remains, $\Theta(q^2/2^c)$.
  - HMAC: Pr[tag collision among the q messages] $\approx \Theta(q^2\ell/2^c)$.

Distinguishing advantage $\approx \Theta(q^2\ell/2^c) - \Theta(q^2/2^c) \approx \Theta(q^2\ell/2^c)$

Conclusion

Xiamen University

What is settled

- HMAC and NMAC now have tight generic PRF bounds in the ideal compression-function model.
- The bounds simultaneously capture online queries q, offline queries p, and maximal length ℓ.
- The proofs are conducted in the multi-user model and avoid the usual hybrid loss in the number of users.
- Matching attacks show the two leading terms are essentially tight.

What remains open

- The techniques here may also help promote tight generic analyses of other hash-based MAC designs.
- Broader research directions beyond geneci PRF security: distinguish-H, universal forgery, state recovery, etc.

More details can be found in ePrint 2025/2260

Thanks!